SAP-C02 Domain 1 — Design Solutions for Organizational Complexity

Average question, answer template and traps for tasks 1.1–1.5 · built from the 160 Domain 1 questions in your trainer

The average Domain 1 question

> "A company has **many accounts in AWS Organizations**. Something must be **connected / shared / allowed / blocked / deployed / seen / paid for** across **all accounts, including new ones**, **centrally**, and member accounts **must not change it**. Which solution has the **LEAST operational overhead**?"

The average answer has 4 parts

- **Where:** one central account (network, security, backup or delegated admin account).
- **What:** one managed AWS feature built for the job.
- **How it reaches every account:** RAM, SCP/RCP, StackSets, auto-enable, organization trail, tag policy.
- **How it's locked:** deny SCP, compliance mode, policies members can't edit.

The wording tells you which answer wins

- **LEAST overhead** → one managed, centrally shared feature.
- **MOST cost-effective** → cheapest option that *just* meets the numbers.
- **MOST secure** → least privilege, temporary credentials, ExternalId.
- **"prevent" / "must not"** → deny SCP, RCP or Hooks (never Config alone).
- **"new / future accounts"** → auto-enable, StackSets auto-deploy, Account Factory.
- **"not the management account"** → delegated administrator.

The 5 "who" checks

Who	Rule
owns it?	One central account; others get access by sharing, never by copying.
runs it daily?	Delegated admin, not the management account. Exceptions (set in the management account): tags, Cost and Usage Report, Budgets, Savings Plans, SCPs.
may use it?	Both sides must allow: resource / trust / key policy **and** the caller's IAM policy.
can't undo it?	Deny SCP; compliance mode; RCP for outside callers.
pays?	Tags activated in the management account + Cost Categories + Cost and Usage Report.

Reading routine

- **Last sentence first:** MOST/LEAST words, how many answers to pick.
- Underline: **scale** (how many accounts, new ones coming?) · **what** is shared or controlled · **hard limits** (overlapping CIDRs, "even root", "no custom code", RTO/RPO).
- Cross out: custom code, per-account setup, the facts below.

Wrong almost every time: custom Lambda + EventBridge/SNS or scripts (42 wrong vs 7 right in Domain 1) · "configure it in each account" · an SCP that "grants" or "shares" · VPC peering for many VPCs (not transitive, fails with overlapping CIDRs) · sharing an AWS managed KMS key · RAM sharing VPN connections, secrets or KMS keys · Config "preventing" anything · governance mode where "even root" applies · SCPs limiting the management account or outside principals · member accounts activating cost tags · invited accounts having OrganizationAccountAccessRole.

1.1 Network connectivity across accounts

> **Q:** [N] accounts, VPCs / Regions / on-premises. [Something] must connect / reach privately / be filtered / resolve names. [CIDRs overlap? only some VPCs may talk? approve each connection?] LEAST overhead?
> **A:** One central network resource in a network account → **shared with RAM** → attach or associate each VPC → control with route tables / segments / acceptance.

What is shared	Answer	Control
Whole network (VPC↔VPC, on-premises)	Transit Gateway (many Regions: Cloud WAN)	TGW route tables / segments
One service (API, database)	PrivateLink: NLB + endpoint service (microservices: VPC Lattice; DB connections: + RDS Proxy)	Require acceptance; allowed principals
Internet egress	Egress VPC: NAT gateway + Network Firewall	Default routes; appliance mode
IP list / IP plan	Customer-managed prefix list / VPC IPAM	SGs reference it; SCP requires IPAM
DNS names	Route 53 Resolver inbound + outbound endpoints	Forwarding rules shared with RAM
Hybrid link	DX gateway + transit VIF, VPN as backup	BGP prefers Direct Connect

Checks: overlapping CIDRs → PrivateLink, Lattice or private NAT (no peering or plain TGW) · whole network vs one service · many accounts → one resource shared by RAM.

1.2 Security controls across accounts

> **Q:** [who: user, team, app, Lambda, partner, auditors] in account A must [assume a role / read encrypted data / sign in / see findings] in account B or all accounts, with least privilege, one identity source, temporary credentials, covering new accounts.
> **A:** Allow in **both places**: the role / resource / key policy in account B names the caller, and the caller's IAM policy allows the action. Use roles, a delegated admin and auto-enable.

Who needs access	Answer
Workload or admin in another account	Role in target + `sts:AssumeRole`; trust policy names the caller
Third party (another organization)	Role with **ExternalId**
Management account → member account	OrganizationAccountAccessRole (created accounts have it; invited accounts need it added)
Employees (Okta, Entra ID, AD)	IAM Identity Center + SAML + SCIM; permission sets per group
Encrypted S3 in another account	Bucket policy + KMS key policy (`kms:Decrypt`) + caller's IAM policy; customer managed key
Some columns / rows · bucket policy too big	Lake Formation data filters · S3 Access Grants
Teams in one account	ABAC: session tag must match resource tag
Security tools / auditors / outside sharing	Delegated admin + auto-enable · Config conformance packs + aggregator · IAM Access Analyzer

1.3 Reliable and resilient architectures

Q: [workload] in [Region / AZs / on-premises]. RTO [time], RPO [time] for [AZ / Region / account compromise], at lowest cost / no data loss / manual control / nobody can delete backups.
A: Match the **numbers** to the cheapest pattern that meets them, then pick the AWS feature built for that exact event.

RTO / RPO	Pattern
hours / hours, nothing running	Backup & restore (AWS Backup copy to DR Region + CloudFormation)
hours / minutes	Pilot light (data replicates, ASG at 0)
minutes	Warm standby
near zero	Active-active
on-premises servers, RPO seconds	Elastic Disaster Recovery

Event	Feature
Aurora: planned, no data loss	Global DB **switchover**
Aurora: real outage	Global DB **failover** (allow data loss)
DynamoDB, RPO 0, latest everywhere	Global tables, multi-Region strong consistency
S3 within 15 min + old objects	RTC + Batch Replication
RDS failover <35 s, readable standby	Multi-AZ DB cluster
Manual Region failover	ARC routing controls + safety rule
Auto move away from a bad AZ	Zonal autoshift + pre-provisioned capacity
One orchestrated failover	ARC Region switch plan
Prove / measure resilience	Fault Injection Service · Resilience Hub

Backups that survive ransomware

- Cross-account vault + **Vault Lock compliance mode** + SCP; backup policies from a delegated admin.
- AWS managed key can't be shared → re-encrypt with a customer managed key.
- Restore without copying → logically air-gapped vault shared with RAM.

Checks: hours / minutes / seconds → pattern (cheapest that fits) · planned → switchover, outage → failover · "even root" → compliance mode. Traps: detach-and-promote, governance mode, health-check failover that flaps, readiness checks (closed).

1.4 Multi-account environment

Q: [N] accounts (often Control Tower). Must block / enforce / deploy / report / see [something] in all current and future accounts or one OU; members can't change it. LEAST overhead.
A: Organization-wide feature from the management or delegated admin account.

Need	Answer
Block Regions / types / tags / public IP	Deny SCP + condition (`aws:RequestedRegion`, `ec2:InstanceType`, `aws:RequestTag`)
Allowed tag values	Tag policy + deny SCP
Outside callers, all repositories	RCP with `aws:PrincipalOrgID`
Same resources everywhere	StackSets (service-managed, auto-deploy)
Config rules everywhere	Organization conformance pack
New accounts with baseline	Control Tower Account Factory + blueprints
Block bad CloudFormation	CloudFormation Hooks

Need	Answer
All API calls	Organization CloudTrail trail
One security view · WAF everywhere	Security Hub delegated admin · Firewall Manager
Quotas for new accounts	Service Quotas template (management account, us-east-1)
Share CA / subnets	AWS RAM
Cost per team	Tag activated in management account + Cost and Usage Report + Athena

SCP facts: never grants · allow-list needs FullAWSAccess removed · root deny applies to all OUs · check SCPs and permissions boundaries when IAM looks right.

1.5 Cost visibility and optimization

Q: [N] accounts spend [amount] on [EC2 / Fargate / Lambda / databases / data transfer]; usage is steady / changing / spiky; plans to change families, Graviton, Fargate or Region. MOST savings / alerts / chargeback / stop overspending, no custom code.
A: Centrally in the management account with the built-in feature.

Need	Answer
Compute that will change	Compute Savings Plan (org level)
Databases that will change	Database Savings Plan (1 yr)
Identical EC2, MOST savings	Standard RI, 3 yr All Upfront
Alert / block at a limit	Budgets + budget action applying an SCP
Unusual spike	Cost Anomaly Detection
Rightsize (CPU + memory)	Compute Optimizer + CloudWatch agent

Need	Answer
Bad / missing tags	Tag policy + deny SCP + Config aggregator; activate + backfill
Split shared costs	Cost Categories + split charge
Hourly SQL analysis	CUR 2.0 (Data Exports) + Athena
Bill subsidiaries with markup	Billing Conductor
S3 traffic through NAT	S3 gateway endpoint (free)
Retry-safe batch	Spot, mixed instances, all AZs

Checks: will it change? → most flexible Savings Plan · alert or block? → Budgets / budget action · NAT or cross-AZ traffic? → gateway endpoint, AZ-local endpoints. Traps: EC2 Instance SP for Fargate, No Upfront for "MOST savings", IAM policy as a spend limit, interface endpoint for S3.